

的 label, 最终确定主体是否能够存取客体。

当某一用户(或主体)以标记 label 注册入系统时, 系统要求他对任何客体的存取必须遵循如下规则:

- ① 仅当主体的许可证级别大于或等于客体的密级时, 该主体才能读取相应的客体。
- ② 仅当主体的许可证级别小于或等于客体的密级时, 该主体才能写相应的客体。

这些系统规定: 仅当主体的许可证级别小于或等于客体的密级时, 该主体才能写相应的客体, 即用户可以为写入的数据对象赋予高于自己许可证级别的密级。这样一旦数据被写入, 该用户自己也不能再读该数据对象了。

规则①的含义是明显的, 而规则②需要解释一下。按照规则②, 用户可以为写入的数据对象赋予高于自己的许可证级别的密级。这样一旦数据被写入, 该用户自己也不能再读该数据对象了。如果违反了规则②, 就有可能把数据的密级从高流向低, 造成数据的泄漏。

例如, 某个绝密级的用户把一个绝密级别的数据恶意地降低为公开级别, 然后把它写回, 这样原来是绝密的数据大家都可以读到了, 造成了绝密级数据的泄漏。

这两种规则的共同点在于, 它们均禁止了拥有高许可证级别的主体更新低密级的数据对象, 从而防止了敏感数据的泄漏。

强制存取控制是对数据本身进行密级标记, 无论数据如何复制, 标记与数据是一个不可分的整体。只有符合密级标记要求的用户才可以操纵数据, 从而提供了更高级别的安全性。

前面已经提到, 较高安全性级别提供的安全保护包含较低级别的所有保护, 因此在实现强制存取控制时要首先实现自主存取控制, 即自主存取控制与强制存取控制共同构成数据库管理系统的安全机制。图 4.4 为数据库管理系统的安全检查示意图, 系统首先进行自主存取控制(DAC)检查, 对通过 DAC 检查的允许存取的数据对象, 再由系统自动进行强制存取控制(MAC)检查, 只有通过 MAC 检查的数据对象方可存取。



图 4.4 数据库管理系统的安全检查示意图

4.3 视图机制

前已提及, 视图具有安全保护的功能。为不同的用户定义不同的视图, 就可以把数据对象限制在一定的范围内, 通过视图机制把保密的数据对无权存取的用户隐藏起来, 从而自动对数据提供一定程度的安全保护。

视图机制还可以和授权机制相配合, 间接地实现支持存取谓词的用户权限定义。例如, 假定王平老师只能查询计算机科学与技术专业学生的信息, 专业负责人张明老师具有查询和增删改该专业学生信息的所有权限。这就要求系统能支持存取谓词的用户权限定义。在不直接支持存取谓词的系统中, 可以先建立计算机科学与技术专业学生的视图 CS_Student, 然后在视图上

进一步定义存取权限。

[例 4.17] 建立计算机科学与技术专业学生的视图, 把对该视图的 SELECT 权限授予王平, 把该视图上的所有操作权限授予张明。

```
CREATE VIEW CS_Student    /* 先建立视图 CS_Student */
AS
SELECT *
FROM Student
WHERE Smajor='计算机科学与技术'
WITH CHECK OPTION;      /* 对该视图进行增、删、改时, 必须满足 */
                        /* Smajor='计算机科学与技术'的条件 */
GRANT SELECT              /* 王平老师只能查询计算机科学与技术学生的信息 */
ON CS_Student
TO 王平;
GRANT ALL PRIVILEGES     /* 专业负责人张明具有查询和增、删、改该视图的所有权限 */
ON CS_Student
TO 张明;
```

4.4 审 计

数据库安全审计系统提供了一种事后检查的安全机制。前面讲的用户身份鉴别、存取控制是数据库安全保护的重要技术(安全策略方面), 但不是全部。审计(audit)功能就是数据库管理系统达到 C2 以上安全级别必不可少的一项指标。

任何系统的安全保护措施都不是完美无缺的, 蓄意盗窃、破坏数据的人总是想方设法打破控制。审计功能把用户对数据库的所有操作自动记录下来放入审计日志(audit log)。审计员可以利用审计日志监控数据库中的各种行为, 重现导致数据库现有状况的一系列事件, 找出非法存取数据的人、时间和内容等; 还可以通过对审计日志分析, 对潜在的威胁提前采取措施加以防范。

审计通常是很费时间和空间的, 所以数据库管理系统往往都将审计设置为可选特征, 允许数据库管理员根据具体应用对安全性要求灵活地打开或关闭审计功能。审计功能主要用于安全性要求较高的部门。它能对普通和特权用户行为、各种表操作、身份鉴别、自主和强制访问控制等操作进行审计。它既能审计成功操作, 也能审计失败操作。

1. 审计事件

审计事件一般有多种类别, 例如:

① 服务器事件。审计数据库服务器发生的事件, 包含数据库服务器的启动、停止、数据库服务器配置文件的重新加载等。